

Clase 175 — Persistencia en Active Directory

Parte: **7 — Red Team y operaciones ofensivas** · Fuente: *The Hacker Recipes / MITRE ATT&CK Persistence (TA0003)* 🕒 Duración estimada: **100 min** · Nivel: **Experto**

🎯 Objetivo

Estudiar las técnicas para mantener el acceso a un dominio comprometido a lo largo del tiempo, sobreviviendo a reinicios y remediaciones parciales: DCSshadow, AdminSDHolder, delegación abusiva, ACLs persistentes, Golden/Diamond Ticket y cuentas ocultas. El alumno aprenderá a instalar y, sobre todo, a **detectar y erradicar** persistencia en su AD lab.

📖 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Instalar** persistencia basada en ACLs (AdminSDHolder, DCSync rights) en el lab.
2. **Explicar** DCSshadow y por qué es difícil de detectar.
3. **Abusar** de delegación (constrained/unconstrained) como persistencia.
4. **Comparar** técnicas por sigilo y durabilidad.
5. **Diseñar** un plan de erradicación tras un compromiso.

📚 Temas

#	Tema	Por qué importa
1	AdminSDHolder / SDProp	Reinyecta permisos cada hora
2	ACLs persistentes	DCSync rights a un usuario "normal"
3	DCShadow	Registrar un DC falso para escribir cambios
4	Delegación abusiva	RBCD, unconstrained como backdoor
5	Diamond/Golden Ticket	Persistencia por tickets forjados
6	Cuentas y credenciales ocultas	Shadow admins, DSRM
7	Erradicación	Cómo el Blue Team limpia de verdad

📖 Definiciones y características

- **AdminSDHolder:** objeto cuya ACL se propaga a cuentas protegidas cada ~60 min (SDProp).
Característica: modificarla reinyecta permisos aunque los borren.
- **DCShadow:** registrar temporalmente un DC ilegítimo para inyectar cambios replicados.
Característica: evita muchos logs de modificación.
- **RBCD (Resource-Based Constrained Delegation):** delegación configurable por el objeto destino.
Característica: abusable como puerta trasera de acceso.

- **DSRM**: cuenta de recuperación local del DC. Característica: su uso como logon de red es una persistencia sigilosa.
- **Diamond Ticket**: TGT modificado (no forjado desde cero) para parecer legítimo. Característica: más difícil de detectar que el Golden.
- **Shadow admin**: cuenta sin membresía obvia pero con permisos equivalentes vía ACLs. Característica: invisible a auditorías superficiales.

Herramientas y preparación

- AD lab / GOAD con acceso previo de alto privilegio (de la Clase 174).
- **Mimikatz** (DCShadow, DSRM), **PowerView**/ `Set-DomainObjectOwner`, **Impacket**, **Rubeus** para tickets.
- Sysmon + auditoría de cambios en AD (Parte 8) para la fase de detección.

⚠ Instalar persistencia se practica **solo** en tu AD lab. En un engagement real, toda persistencia debe registrarse meticulosamente y **retirarse** al finalizar; dejar puertas traseras es negligente e ilegal. El foco pedagógico aquí es la erradicación tanto como la instalación.

Laboratorio guiado

1. **ACL DCSync persistente**. Concede a un usuario de bajo privilegio los derechos de replicación:

```
text Add-DomainObjectAcl -TargetIdentity 'DC=lab,DC=local' -PrincipalIdentity lowuser -Rights DCSync
```

Verifica que ahora puede hacer DCSync. 2. **AdminSDHolder**. Añade una ACE a `CN=AdminSDHolder,CN=System, ...` para tu usuario y espera al ciclo SDProp; comprueba que recupera permisos sobre cuentas protegidas. 3. **DCShadow (estudio)**. Con Mimikatz, comprende cómo `lsadump::dcshadow` registra un DC falso para escribir un atributo (ej. SID History) evitando logs habituales. 4. **RBCD como backdoor**. Configura delegación basada en recursos sobre una máquina para poder impersonar administradores hacia ella. 5. **DSRM**. Estudia cómo habilitar el logon de red con la cuenta DSRM del DC y por qué es persistencia sigilosa. 6. **Detección**. Audita cambios de ACL (evento 5136), la cuenta AdminSDHolder y objetos con delegación inusual. 7. **Erradicación**. Escribe y ejecuta un checklist: revisar ACLs, resetear krbtgt dos veces, revisar delegaciones, DSRM y cuentas ocultas.

Ejercicios

1. Instala persistencia por ACL DCSync y demuéstrela.
2. Explica por qué AdminSDHolder es tan resistente a la limpieza.
3. Describe el flujo de DCShadow y qué lo hace sigiloso.
4. Configura RBCD y úsalo para impersonar a un admin en el lab.
5. Compara Golden vs Diamond Ticket en detectabilidad.
6. Redacta un checklist de erradicación de persistencia en AD.

Reto verificable

Instala **dos técnicas de persistencia distintas** en tu AD lab, luego cambia de rol y **detéctalas y erradícalas** documentando cómo lo harías como Blue Team. **Criterio de aceptación:** demuestras que ambas persistencias otorgan acceso tras un "reinicio" o cambio de contraseña de la cuenta original, y luego presentas los eventos/consultas que las detectan y el procedimiento que las elimina por completo. Todo en tu laboratorio.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
La persistencia por ACL se borra	No usaste AdminSDHolder; SDProp la reinyecta si la pones ahí
DCShadow falla	Requiere privilegios altos y condiciones específicas; revisa requisitos
RBCD no impersona	msDS-AllowedToActOnBehalfOfOtherIdentity mal configurado; corrige el descriptor
Erradicación incompleta	Olvidaste resetear krbtgt (x2) o revisar delegaciones; usa el checklist
Persistencia detectada al instante	Cambios de ACL auditados (5136); es telemetría esperable

Preguntas frecuentes

? ¿Por qué basta un reset simple de contraseñas para NO limpiar el dominio? Porque la persistencia moderna vive en ACLs, delegaciones y krbtgt, no en contraseñas de usuario. La erradicación exige revisar el directorio, no solo credenciales.

? ¿DCShadow deja rastro? Menos que una modificación normal, pero el registro efímero del DC falso y ciertos eventos de replicación pueden delatarlo con la auditoría adecuada.

? ¿Cuándo se retira la persistencia en un engagement real? Siempre al cierre, con inventario completo de lo instalado. Dejar persistencia es una falta grave: se documenta y se elimina.

Referencias

- The Hacker Recipes — *AD persistence*. <https://www.thehacker.recipes/ad/persistence/>
- MITRE ATT&CK — *Persistence* (TA0003). <https://attack.mitre.org/tactics/TA0003/>
- Microsoft — *AdminSDHolder / SDProp*. <https://learn.microsoft.com/>
- SpecterOps — research sobre RBCD y delegación.

Siguiente clase

Clase 176 - OPSEC ofensiva